

主打团代码审计

底层工程素质很高，但守门的闸没接上量尺——质量工具建得比多数团队都完整，却在量一个已经不存在的仓库。

main/ · 85,826 TS/TSX HEAD 01f1ed4 + 188 2026-08-29

Node 22.22.3

总评

VERDICT

这不是「代码写得烂」的问题。恰恰相反——核心是写得相当克制、相当专业的 TypeScript 后端。

问题出在围绕它建的那套质量工具：它们写死了一个 6 个 app 的旧布局，而实际仓库只剩 3 个且改了名。CI 又不跑那套工具，所以断层一直没被发现。

结果是 约 69% 的代码从来没被 ESLint 检查过，而 11 项架构审计里有 10 项是红的。但同时，typecheck 全绿、927 个单元测试全过、27,211 行 canonical API 里零个 any。

0 services/commerce 的 any (27,211 行)	0 全库 TODO / FIXME / HACK	927 单元测试通过，0 失败	10/11 架构审计失败
69% 代码未纳入 ESLint	188 未提交的变更项		

真正扎实的部分

类型纪律做到顶格

`tsconfig.json` 开了 `noUncheckedIndexedAccess` 和 `exactOptionalPropertyTypes` ——多数团队会跳过的两个最难的 flag，加上 `useUnknownInCatchVariables` 和 `noImplicitOverride`。

而且是真的守住了，不是开了就靠 `any` 逃逸：`services/commerce` 全部 27,211 行零个 `any`，`packages/` 也是零，全库 85,826 行零个 TODO 标记。`npm run typecheck` 退出码 0。

财务代码是真懂行的人写的

`modules/finance/application/command/PostJournal.ts` 里有一整套正确做法：事务型 `inbox/outbox` 配 `for update of inbox` 行锁、`processed_at` 幂等、金额全程整数 `minor unit` 且用 `::text` 转出躲开 JS 大整数精度损失、`safeAdd` 溢出保护、标准复式记账。

最漂亮的一手是**证据反查**：事件到达后不信 `payload`，回数据库重读订单事实再逐项比对（币别、总额、`tender` 序列），对不上就抛 `FINANCE_ORDER_EVIDENCE_MISMATCH`。这是防事件伪造与漂移的做法，一般团队不会写到这个份上。

架构是自己搭的，不是框架堆的

`bootstrap/Container.ts` 是 25 行的 DI 容器，`ModuleRegistry.ts` 做拓扑排序带环检测。26 个模块一致遵守 `domain / application / infrastructure / interface` 分层。225 个 `Operation` 由 `packages/contract/definitions/operations.yml` 生成，并用 `satisfies readonly OperationId[]` 拿到编译期穷尽检查。

行预算设在 299 行，最大文件 707 行。这种克制在 8 万行规模的项目里不常见。

核心断层

ESLint 覆盖范围 (TS/TSX 行数)

services/commerce		27,211
apps/storefront-web		12,034
apps/console		11,894
packages		10,553
services/commerce-api		10,025
extensions		3,402
apps/auth-web		3,083
tools		2,646
packages/api-contract		525
packages/smart-wing-authz		242

合计 **59,529** / **69.4%** 落在 ESLint 之外，包括整个 canonical API。逐一用 `eslint --print-config` 验证：这些路径返回 `undefined`，即无任何配置命中。

根因在 `eslint.config.mjs:8`。它的 glob 是

`apps/{auth,console,store,supplier,storefront}/src/**` —— 实际目录却是 `auth-web`、`console`、`storefront-web`，所以只命中 `apps/console` 一个。而 `services/`、`extensions/`、`tools/` 从一开始就没写进任何 config 区块。

CI 跑什么，不跑什么

QUALITY.YML

```
+ check:cleaninstall / check:artifacts
+ check:migrations / test:sql / test:mvp
+ typecheck
+ test:unit / test:contract /
  test:component
+ test:journey / test:security /
  test:performance
+ replay:postgres / test:integration /
  test:adapters
+ build + docker build
+ npm audit --omit=dev
```

CI

```
- lint
- audit:architecture 22
- check:generated
- check:errors
- check:requirements
- check:lines
- check:approved-ui
- check:supplychain
- check:bundles
- test:e2e
```

后果立刻可见——`npm run lint` 现在就是失败的：

```
apps/console/src/components/Header.tsx
  54:48  error  The autoFocus prop should not be used  jsx-a11y/no-autofocus

* 1 problem (1 error, 0 warnings)
```

审计实跑结果

11 · 1 · 10 ·

check:boundaries	PASS	—	—
check:naming	FAIL	A	11 目录 + 35 文件；把 <code>apps/auth-web</code> 、 <code>services/commerce-api</code> 等新名判为违规
check:tests	CRASH	A	ENOENT: <code>apps/auth/package.json</code>
check:ownership	FAIL	B	4 处 <code>SCHEMA_WRITE_OWNER_VIOLATION</code> ，全在 <code>IdentityOperations.ts</code>
check:duplicates	FAIL	B	72 项违规，主要是依赖版本漂移
check:calls	FAIL	A	203 条但只集中在 2 个文件
check:pagination	FAIL	B	<code>PAGE_RESULT_WITHOUT_CURSOR</code>
check:transactions	FAIL	B	事务边界内做 <code>encrypt/decrypt</code> ，3 处
check:lines	FAIL	B	12 个文件超出 299 行预算
check:generated	FAIL	B	<code>GENERATED_REQUIREMENTS_DRIFT</code> : <code>docs/requirements/mvp.yml</code>
check:errors	FAIL	B	<code>ERROR_CONTRACT_MISSING</code>

A 类：工具在量一个已不存在的仓库

GLOB

审计脚本普遍写死了 `['console', 'store', 'supplier', 'storefront', 'auth', 'miniapp']` 这个 6-app 列表。实际仓库只有 `auth-web`、`console`、`storefront-web` 三个。

需要同步改名的位置：

```
eslint.config.mjs:8      webSource glob
scripts/check/frontend.mjs:27  ['auth','console','store','supplier','storefront']
scripts/check/tests.mjs:38    ['auth','console','store','storefront','supplier','miniapp']
scripts/check/deployment.mjs:29      6-app
scripts/check/bundles.mjs:11-13  apps/supplier/dist, apps/auth/dist, apps/storefront/dist
scripts/check-platform-delivery.mjs:25
scripts/evidence/frontendmanifest.mjs:10-13
scripts/release/validate.mjs:7
scripts/release/candidate.mjs:25    supplier: 'apps/supplier/dist'
scripts/verify-p0.mjs:41,48        apps/supplier/vite.config.ts
```

`check:naming` 标记的违规也全部指向同一件事——它判为违规的正是 smart-wing 那套合并进来的部分：`apps/auth-web`、`apps/storefront-web`、`services/commerce-api`、`packages/api-contract`、`packages/design-system`、`packages/smart-wing-authz`。原本的命名约定是单词小写无连字号；合并带进了连字号命名，两边没有对齐。

注意：改完 glob 后第一次跑 lint 会爆出大量问题，因为那 59,529 行从未被检查过。建议分批：先 `services/commerce`（品质最高，预期最少），最后 `storefront-web`。

B 类：真实技术债

IdentityOperations.ts 是三重热点

707 行，全库最大文件，同时被三项不同审计标记。它直接写入其他模块拥有的 schema——正是这套架构存在的目的所要防的跨模块耦合。

```
SCHEMA_WRITE_OWNER_VIOLATION :306 identity → member insert into member.invite
SCHEMA_WRITE_OWNER_VIOLATION :323 identity → member update
SCHEMA_WRITE_OWNER_VIOLATION :422 identity → access update
SCHEMA_WRITE_OWNER_VIOLATION :435 identity → access update
PAGE_RESULT_WITHOUT_CURSOR
TRANSACTION_BOUNDARY :170 decrypt
TRANSACTION_BOUNDARY :558 decrypt
TRANSACTION_BOUNDARY :560 encrypt
```

事务内做加解密会拉长持锁时间，在身份热路径上尤其值得拆出去。

依赖版本漂移 72

@types/node 分裂成 ^22.14.0 (auth-web、commerce-api) 与 22.19.19 (约 30 个其他 package) 两支。

```
@types/node          ^22.14.0 vs 22.19.19      ~30 package
@tailwindcss/vite     ^4.1.14 vs 4.3.3        auth-web vs console
@cloudflare/workers-types ^5.20260724.1 vs 5.20260724.1
```

分界线正好落在 smart-wing 合并的边界上——旧轨用 caret range，新轨用 pin。

跨 workspace 深相对路径引用

check:calls 报 203 条，但只集中在两个文件：

```
apps/storefront-web/src/config/productionDemoAuth.ts
apps/storefront-web/worker/index.ts

import type { MembershipRuntime } from '../../../services/commerce-
api/src/api/membershipContext';
```

README 说明 commerce-api 的 REST Router 由 storefront Worker 同源嵌入，所以耦合本身是有意 的。但用 ../../../../ 穿越 workspace 边界很脆——改成 workspace 依赖或 path alias 即可，不动架构。

品牌名在仓库内不一致

正确的名字是**主打团**，但顶层 canonical 文档全部写成了「築大團」——包括三份最重要的：

```
README.md                docs/brand/README.md
DEPLOYMENT.md            docs/brand/CHANGELOG.md
SOURCE-MANIFEST.md        docs/brand/ZHUDATUAN-DESIGN-SYSTEM-VI-1.1.md
projects/hbbtzn/README.md docs/operations/2026-08-28-zhudatuan-vi-1.1-upgrade.md
docs/decisions/zhudatuan.md docs/evidence/vi/2026-08-28/README.md
docs/decisions/          .md packages/design/src/VI11.stories.tsx
```

品牌文档和设计包用的是对的，入口文档用的是错的。 docs/decisions/ .md 两种写法同时存在。此外这批文档是繁体，与简体正名不一致。

行预算超标 12 个

299

```
1511 apps/auth-web/src/screens/LoginPage.tsx
1461 apps/console/src/smart-wing-vi.css
928  apps/console/src/legacy-admin-theme.css
707  services/commerce/src/modules/identity/IdentityOperations.ts
521  apps/auth-web/src/services/auth.ts
434  services/commerce/src/modules/finance/.../ReconcileStatement.ts
415  services/commerce/src/modules/payment/PaymentJobs.ts
388  apps/storefront-web/src/context/MallContext.tsx
387  services/commerce-api/src/api/publicRoutes.ts
```

工作树已领先于已提交状态

main/README.md 声称 **217 operations / 165 migrations**——对照 HEAD 01f1ed4 的已提交内容，这两个数字完全准确，文档没有漂移。

工作树里数出来是 **225 / 171**，多出的 8 个 operation 和 6 个 migration 全部来自那 188 项未提交的改动。这不是文档问题，是**发现 1 的另一个侧面**：正式合同和数据库 schema 已经改了，但只存在于本地。

真正的生成物漂移只有一处： docs/requirements/mvp.yml 与生成源头不同步（ check:generated 失败）。

测试分布

finance 9 / 39	identity 5 / 16	payment 4 / 16	voucher 1 / 11
benefit 1 / 7	catalog 0 / 10	checkout 0 / 9	order 0 / 7
access 0 / 4	cart 0 / 3		

下单／结算主链路（order、checkout、cart）在模块级是**零单元测试**。这条路径可能靠 `tests/journeys` 覆盖，而那套 CI 有跑——所以不是「完全没测」，但缺少能快速定位问题的模块级测试。

相对地，finance 和 payment 的覆盖是实打实的，也和那两个模块代码品质最高的观察一致。

建议顺序

1

先落盘

现在有 113 个已改 + 75 个未追踪 = **188 项未提交**，`+8,348 / -2,478` 行横跨 113 个文件，其中包含两个新的 database migration：

```
database/supabase/migrations/20260828091000_finance_reconciliation_integrity.sql
database/supabase/migrations/20260828092000_finance_security_boundaries.sql
```

这个项目历史上习惯用「复制整个文件夹」开分支。这批东西裸放着是目前最大的单点风险。

2

修 glob，让 59,529 行进入检查

把上面列出的 10 处旧 app 名改成实际名字，并把 `services/`、`extensions/`、`tools/` 加进 ESLint config。改动极小，但要分批消化爆出来的问题。

3 把 lint 和 audit:architecture 接进 CI

尺子已经造好了——22 项自建审计是这个项目最有价值的资产之一，不接上等于白造。建议先设为 `continue-on-error` 收集基线，清干净后再改成硬性门槛。

.

4 拆 IdentityOperations.ts

唯一一个同时违反三条架构规则的文件，也是全库最大。把 `member.invite` 和 `access.*` 的写入改成经由对应模块的 port，加解密移出事务边界。

· OWNER

顺带一提：`apps/console/src/features/`（复数）是 29 个空目录、0 个文件、git 完全未追踪，纯本地残留，可直接删除。真正在用的是单数的 `feature/`，150 个文件。

覆核指令

.

```
cd /Users/Ethan/Desktop/Projects/zhudatuan/main
```

```
#
npm run typecheck          # 0
npm run test:unit          # 927 pass / 0 fail
```

```
#
npm run lint               # 1 error, Header.tsx:54
npx eslint --print-config services/commerce/src/entry/ApiMain.ts # undefined =
npx eslint --print-config apps/auth-web/src/main.tsx             # undefined =
```

```
#
npm run check:naming check:ownership check:duplicates
npm run check:pagination check:transactions check:lines
npm run check:generated check:errors
```

```
#
grep -rl " " . --exclude-dir=node_modules # 6
grep -rl " " . --exclude-dir=node_modules # 7
```

```
#
git status --porcelain | wc -l          # 188
git diff --shortstat                   # 113 files, +8348 -2478
```

```
#
git show 01f1ed4:packages/contract/definitions/operations.yml | grep -c '^ - id:' # 217  README

grep -c '^ - id:' packages/contract/definitions/operations.yml # 225
git ls-tree -r --name-only 01f1ed4 database/supabase/migrations/ | grep -c '\.sql$' # 165  README

ls database/supabase/migrations/*.sql | wc -l # 171
```

Git	B	README	Owner
-----	---	--------	-------

```
find . -name node_modules -prune -o -name "*.ts" -o -name "*.tsx"
```

85,826